

Reco Backend API Documentation

Stack: Spring Boot 4.0.6 · Java 21 · PostgreSQL · JWT Auth

Base URL: `http://localhost:8080/api/v1`

Global Security Rules

Pattern	HTTP Method	Access
<code>/api/v1/auth/**</code>	ALL	✓ Public
<code>/api/v1/products/**</code>	GET	✓ Public
<code>/api/v1/categories/**</code>	GET	✓ Public
<code>/api/v1/reviews/product/**</code>	GET	✓ Public
Everything else	ALL	🔒 Authenticated (valid JWT)

CORS: All origins, methods `GET POST PUT DELETE PATCH OPTIONS`, all headers, no credentials

Session: Stateless (JWT)

CSRF: Disabled

Auth Header Format

```
Authorization: Bearer <accessToken>
```

Auth Module

Base: `/api/v1/auth`

POST `/api/v1/auth/register`

Create a new customer account.

Public

Request:

```
{
  "firstName": "John",
  "lastName": "Doe",
  "username": "johndoe",
  "email": "john@example.com",
  "password": "securepassword"
}
```

Response `201 Created`:

```
{
  "accessToken": "eyJhbGciOiJIUzI1...",
  "expiresIn": 900000,
  "email": "john@example.com",
  "firstName": "John",
  "lastName": "Doe",
  "role": "CUSTOMER"
}
```

POST `/api/v1/auth/login`

Authenticate and receive a JWT.

Public

Request:

```
{
  "email": "john@example.com",
  "password": "securepassword"
}
```

Response `200 OK` — same as register.

POST `/api/v1/auth/register-admin`

Create a new admin account.

 **ADMIN only**

Request: Same structure as register.

Response: `201 Created` with `"role": "ADMIN"`.

Product Module

Base: `/api/v1/products`

GET `/api/v1/products`

List/paginate/search products.

 **Public (GET)**

Query Params:

Param	Type	Default	Description
<code>page</code>	int	<code>0</code>	Page number (zero-indexed)

Param	Type	Default	Description
limit	int	20	Items per page
categoryId	Long	—	Filter by category
q	String	—	Search term (matches name and description)
sort	String	name	Sort field
order	String	asc	Sort direction (asc / desc)

Response 200 OK:

```
{
  "content": [
    {
      "id": 1,
      "categoryId": 1,
      "name": "Wireless Mouse",
      "description": "Ergonomic wireless mouse",
      "price": 29.99,
      "stockQuantity": 100,
      "tags": "electronics,mouse,wireless",
      "avgRating": 4.2,
      "totalClicks": 150,
      "totalCartAdds": 45,
      "popularityScore": 85.5,
      "createdAt": "2026-05-17T00:00:00Z"
    }
  ],
  "totalElements": 1,
  "totalPages": 1,
  "number": 0,
  "size": 20
}
```

GET /api/v1/products/{productId}

Get a single product by ID.

✔ **Public (GET)**

Response 200 OK — single ProductResponse object.

POST /api/v1/products

Create a new product.

 **ADMIN only**

Request:

```
{
  "categoryId": 1,
  "name": "Wireless Mouse",
  "description": "Ergonomic wireless mouse",
  "price": 29.99,
  "stockQuantity": 100,
  "tags": "electronics,mouse,wireless"
}
```

Response 201 Created — ProductResponse.

PUT /api/v1/products/{productId}

Fully update a product.

 **ADMIN only**

Request: Same as POST.

Response 200 OK — updated ProductResponse.

DELETE /api/v1/products/{productId}

Delete a product.

 **ADMIN only**

Response 204 No Content.

Category Module

Base: /api/v1/categories

GET /api/v1/categories

List all categories.

 **Public (GET)**

Response 200 OK:

```
[
  {
    "id": 1,
    "name": "Electronics",
    "description": "Electronic devices and accessories"
  }
]
```

GET /api/v1/categories/{categoryId}

Get a single category.

✓ Public (GET)

POST /api/v1/categories

Create a category.

🔒 ADMIN only

Request:

```
{
  "name": "Electronics",
  "description": "Electronic devices and accessories"
}
```

Response 201 Created.

PUT /api/v1/categories/{categoryId}

Update a category.

🔒 ADMIN only

Request:

```
{
  "name": "Electronics",
  "description": "Updated description"
}
```

Response 200 OK.

DELETE /api/v1/categories/{categoryId}

Delete a category.

 **ADMIN only**

Response 204 No Content .

User Module

Base: /api/v1/users

GET /api/v1/users/me

Get the currently authenticated user's profile.

 **Authenticated**

Response 200 OK:

```
{
  "id": 1,
  "firstName": "John",
  "lastName": "Doe",
  "username": "johndoe",
  "email": "john@example.com",
  "role": "CUSTOMER",
  "createdAt": "2026-05-17T00:00:00Z"
}
```

GET /api/v1/users/{userId}

Get a user by ID.

 **Authenticated**

Response 200 OK.

GET /api/v1/users

List all users.

 **ADMIN only**

Response 200 OK — array of `UserResponse` .

PUT /api/v1/users/{userId}

Update user profile.

 **Authenticated** (owner or admin)

Request:

```
{
  "firstName": "John",
  "lastName": "Smith",
  "username": "johnsmith",
  "email": "john@example.com",
  "passwordHash": "current_password_hash"
}
```

Response 200 OK.

PATCH /api/v1/users/{userId}/password

Update user password.

 **Authenticated** (owner)

Request:

```
{
  "oldPassword": "currentpassword",
  "newPassword": "newpassword",
  "confirmPassword": "newpassword"
}
```

Response 200 OK.

DELETE /api/v1/users/{userId}

Delete a user account.

 **Authenticated** (owner or admin)

Response 204 No Content.

Cart Module

Base: /api/v1/cart

GET /api/v1/cart

Get the current user's cart.

 **CUSTOMER only**

Response 200 OK:

```
{
  "cartId": 1,
  "updatedAt": "2026-05-17T00:00:00Z",
  "items": [
    {
      "productId": 1,
      "productName": "Wireless Mouse",
      "unitPrice": 29.99,
      "quantity": 2,
      "lineTotal": 59.98
    }
  ],
  "totalQuantity": 2,
  "subtotal": 59.98
}
```

POST /api/v1/cart/items

Add a product to cart.

 **CUSTOMER only**

Request:

```
{
  "productId": 1,
  "quantity": 2
}
```

Response 201 Created — CartResponse.

PUT /api/v1/cart/items/{productId}

Update item quantity.

 **CUSTOMER only**

Request:

```
{
  "quantity": 3
}
```


Response 200 OK — `CartResponse`.

DELETE `/api/v1/cart/items/{productId}`

Remove an item from cart.

 **CUSTOMER only**

Response 204 No Content.

DELETE `/api/v1/cart/clear`

Clear the entire cart.

 **CUSTOMER only**

Response 204 No Content.

Order Module

Base: `/api/v1/orders`

POST `/api/v1/orders`

Create an order from the current user's cart.

 **CUSTOMER only**

Response 201 Created:

```
{
  "id": 1,
  "userId": 1,
  "totalAmount": 59.98,
  "status": "PENDING",
  "createdAt": "2026-05-17T00:00:00Z",
  "items": [
    {
      "productId": 1,
      "productName": "Wireless Mouse",
      "quantity": 2,
      "priceAtPurchase": 29.99,
      "lineTotal": 59.98
    }
  ]
}
```

GET /api/v1/orders

List current user's orders.

 **CUSTOMER** only

Query Params:

Param	Type	Description
status	OrderStatus	Optional filter: PENDING, COMPLETED, CANCELLED

Response 200 OK — array of OrderResponse .

GET /api/v1/orders/{orderId}

Get a specific order.

 **Authenticated** (owner or admin)

Response 200 OK .

GET /api/v1/orders/{orderId}/items

Get line items for an order.

 **Authenticated** (owner or admin)

Response 200 OK — array of OrderItemResponse .

PUT /api/v1/orders/{orderId}/status

Update order status.

 **ADMIN** only

Request:

```
{
  "status": "COMPLETED"
}
```

Response 200 OK .

DELETE /api/v1/orders/{orderId}

Delete an order.

 **ADMIN only**

Response 204 No Content.

Payment Module

Base: /api/v1

POST /api/v1/orders/{orderId}/payment

Process payment for an order.

 **CUSTOMER only**

Request:

```
{
  "amount": 59.98,
  "paymentMethod": "MOCK_GATEWAY",
  "paymentMethodDetails": "optional details"
}
```

Response 201 Created:

```
{
  "id": 1,
  "orderId": 1,
  "amount": 59.98,
  "status": "SUCCESS",
  "paymentMethod": "MOCK_GATEWAY",
  "transactionDate": "2026-05-17T00:00:00Z"
}
```

GET /api/v1/orders/{orderId}/payment

Get payment for an order.

 **Authenticated** (owner or admin)

Response 200 OK.

GET `/api/v1/payments/{paymentId}`

Get a payment by its ID.

 **Authenticated** (owner or admin)

Response `200 OK`.

Review Module

Base: `/api/v1/reviews`

POST `/api/v1/reviews`

Create a product review.

 **CUSTOMER only** (one review per product per user)

Request:

```
{
  "productId": 1,
  "rating": 4,
  "comment": "Great product!"
}
```

Response `201 Created`:

```
{
  "id": 1,
  "rating": 4,
  "comment": "Great product!",
  "createdAt": "2026-05-17T00:00:00Z",
  "updatedAt": "2026-05-17T00:00:00Z",
  "userId": 1,
  "username": "johndoe",
  "productId": 1
}
```

GET `/api/v1/reviews/product/{productId}`

Get all reviews for a product.

 **Public (GET)**

Response `200 OK` — array of `ReviewResponse`.

GET /api/v1/reviews/product/{productId}/average

Get average rating for a product.

✓ **Public (GET)**

Response 200 OK:

```
{
  "productId": 1,
  "averageRating": 4.2,
  "totalReviews": 15
}
```

GET /api/v1/reviews/user/{userId}

Get reviews by a specific user.

🔒 **Authenticated**

Response 200 OK.

PUT /api/v1/reviews/{reviewId}

Update own review.

🔒 **CUSTOMER only** (owner check in service)

Request:

```
{
  "rating": 5,
  "comment": "Updated review"
}
```

Response 200 OK.

DELETE /api/v1/reviews/{reviewId}

Delete own review.

🔒 **CUSTOMER only** (owner check in service)

Response 204 No Content.

Seed Data

A default admin account is seeded on startup:

Email	Password	Role
admin@admin.com	123456789	ADMIN

Error Responses

All errors follow this format:

```
{
  "timestamp": "2026-05-17T00:00:00",
  "status": 400,
  "error": "Bad Request",
  "message": "Descriptive error message",
  "path": "/api/v1/products"
}
```

Status	Meaning
400 BAD_REQUEST	Validation failure, duplicate, insufficient stock, etc.
401 UNAUTHORIZED	Invalid credentials
403 FORBIDDEN	Insufficient role / access denied
404 NOT_FOUND	Entity not found
500 INTERNAL_SERVER_ERROR	Unhandled exception